

Informe técnico de avance

Entregable 1

State-of-the-Art Review on IoT Authentication, MQTT Security, and Behavioral Anomaly Detection

Proyecto:

*Componentes criptográficos de autenticación para detección y mitigación
inteligente de amenazas en arquitecturas descentralizadas*

Becario: David Alexis Córdova Morales

CVU: 756104

Asesora: Gina Gallegos-García

Institución receptora: Centro de Investigación en Computación, IPN

Periodo reportado: 01/09/2025–31/07/2026

Fecha: Julio de 2026

Resumen

El presente entregable reúne la revisión del estado del arte realizada como parte del proyecto *Componentes criptográficos de autenticación para detección y mitigación inteligente de amenazas en arquitecturas descentralizadas*. Su objetivo es identificar los conceptos, mecanismos y decisiones arquitectónicas necesarios para diseñar un simulador capaz de reproducir procesos de autenticación en sistemas IoT y generar trazas sintéticas orientadas a la detección de anomalías.

La revisión analiza el ciclo de vida de la autenticación en IoT, incluyendo el aprovisionamiento inicial de confianza, la incorporación y el registro de dispositivos, la gestión de identidades y credenciales, la autenticación, la autorización, el establecimiento de sesiones y la renovación de credenciales. Asimismo, se examinan los mecanismos de autenticación adaptados a dispositivos con recursos limitados, las arquitecturas centralizadas, federadas y descentralizadas, y los principales modelos de control de acceso aplicables a entornos IoT.

El estudio también aborda el uso de MQTT como contexto de comunicación, las funciones de seguridad que pueden desplegarse en gateways y nodos de borde, y la aplicación de principios de Zero Trust para complementar la autenticación inicial mediante mecanismos de verificación continua. A partir de esta arquitectura se identifican anomalías específicas, como la reutilización de tokens o nonces, la incoherencia entre identidad, credencial y sesión, el acceso sin autenticación previa, la renovación anormal de credenciales y las desviaciones de comportamiento posteriores a una autenticación válida.

La comparación de conjuntos de datos públicos muestra que las propuestas existentes se concentran principalmente en paquetes, flujos de red y ataques de nivel protocolo. En general, no representan explícitamente el estado interno de la autenticación, las dependencias temporales entre eventos ni la coherencia entre dispositivos, credenciales y sesiones. Esta limitación justifica el desarrollo de un generador sintético especializado en eventos de autenticación.

Como resultado de la revisión, se retiene una arquitectura de referencia compuesta por dispositivos IoT, gateway, servicios de autenticación y recursos MQTT. El futuro simulador deberá representar entidades, estados, transiciones, relaciones temporales y escenarios legítimos o anómalos, conservando etiquetas de referencia que permitan posteriormente evaluar métodos basados en reglas, análisis estadístico o aprendizaje automático. Este entregable constituye, por tanto, la base conceptual para la definición funcional y el diseño del entorno experimental que se desarrollarán en las siguientes etapas del proyecto.

Contents

Resumen	i
1 Introduction	1
2 Review Methodology	1
2.1 Review Scope and Strategy	1
2.2 Selection Criteria	2
2.3 Research Questions	2
3 Cryptographic Authentication in IoT Systems	3
3.1 Device Onboarding and Security Bootstrapping	3
3.2 Device Identity and Credential Management	4
3.3 Authentication Mechanisms for Constrained Devices	5
3.4 Authentication Architectures	7
3.5 Authorization and Access Control	7
4 Messaging, Edge, and Continuous Verification	9
4.1 MQTT Security	9
4.2 Zero Trust Architecture	10
4.3 Edge-Based Security Enforcement	11
5 Authentication Attacks and Behavioral Anomalies	13
5.1 Authentication-Specific Attacks	13
5.2 Behavioral and Post-Authentication Anomalies	14
5.3 Trust Management Systems	15
6 Datasets and Synthetic Data Generation	17
6.1 Existing IoT and MQTT Security Datasets	17
6.2 Synthetic Data Generation	18
6.3 Limitations of Existing Datasets	19
7 Research Gap and Project Positioning	20
7.1 Research Gap	20
7.2 Project Positioning	21
8 Design Choices Derived from the Literature Review	21
8.1 Reference Authentication Model	21
8.2 Retained Architectural and Protocol Choices	22
8.3 Implications for Simulator Design	23

9 Conclusion**24**

1 Introduction

Before designing an IoT authentication-flow simulator, we first had to answer a concrete question: *what does realistic IoT authentication behavior look like, and why do existing datasets not adequately capture it?* This document addresses that question through a structured, project-oriented literature review whose results provide a basis for the functional specification of the simulator.

IoT deployments differ from classical information systems in three ways that directly shape authentication. Devices are physically exposed, computationally constrained, and frequently dependent on a gateway for security enforcement [1, 2, 3]. Authentication is therefore not a single login operation but a **lifecycle**, and an attack may target any of its phases.

2 Review Methodology

2.1 Review Scope and Strategy

The review was driven by the functional requirements of the planned authentication-flow simulator rather than by the objective of producing an exhaustive survey of IoT security. The selected literature was organized into six thematic blocks: (i) authentication and device onboarding [1, 4, 5, 6, 7], (ii) MQTT security mechanisms [2, 8, 9, 10, 11, 12, 13], (iii) Zero Trust and edge-based security architectures [14, 15, 3, 16, 17, 18, 19, 20, 21], (iv) authentication attacks and anomaly detection [22, 23, 24], (v) trust management systems [22], and (vi) IoT security datasets and synthetic data generation [25, 26, 27, 28, 29, 30, 31]. Each block was analyzed with the objective of identifying concepts, mechanisms, attacks, and design elements directly reusable in the simulator.

Table 1 maps each block to its role.

Research Block	Main Contribution	Use in the Project
Authentication and onboarding	Identity, pairing, enrollment, authorization concepts	Authentication lifecycle and device state model
MQTT security	Broker, topic, session, transport risks and overhead	MQTT session fields and abnormal communication indicators
Zero Trust and edge security	Continuous verification and policy enforcement	Gateway as decision and monitoring layer
Attacks and anomaly detection	Replay, impersonation, DoS, compromise scenarios	Attack labels and anomaly injection rules
Trust management	Behavioral trust scoring complementary to cryptography	Trust and on-off detection features
Datasets and synthetic generation	Dataset gaps and reproducibility needs	Justification of labeled synthetic data generation

Table 1: Mapping between literature review blocks and project decisions.

2.2 Selection Criteria

Publications were retained when they contributed directly to the design of the simulator through authentication workflows, architectural elements, attack models, observable features, trust-management concepts, or dataset-generation methodologies. The review therefore prioritizes practical and implementation-oriented contributions over purely theoretical discussions.

2.3 Research Questions

The review was guided by the following questions:

1. How can an IoT device be securely introduced into a network?
2. Which identity and authentication mechanisms are suitable for constrained devices?
3. How does MQTT influence authentication, authorization, and session security?
4. How can Zero Trust principles be applied to IoT authentication workflows?
5. Which authentication attacks and behavioral anomalies should be represented in the simulator?
6. What limitations exist in current IoT and MQTT security datasets?
7. How can synthetic data generation support reproducible cybersecurity experiments?
8. Which architectural and security concepts should be retained for the proposed simulator?

3 Cryptographic Authentication in IoT Systems

3.1 Device Onboarding and Security Bootstrapping

The first security challenge in an IoT environment is establishing an initial trust relationship between a device and the infrastructure to which it connects. This process, commonly referred to as device onboarding or security bootstrapping, encompasses the mechanisms through which a previously unknown device is securely introduced into an operational network and obtains the credentials required for subsequent communications [1, 5, 4].

Bootstrapping is particularly challenging in IoT environments because devices are often deployed in large numbers, possess limited computational resources, and may operate unattended for extended periods. Consequently, onboarding mechanisms must balance security, scalability, and deployment simplicity.

Existing approaches typically rely on one of three trust-establishment models:

- Pre-shared credentials provisioned during manufacturing;
- Certificate-based enrollment using a trusted certification authority;
- Dynamic credential provisioning through a dedicated onboarding service.

Table 2 summarizes the principal onboarding strategies identified in the literature.

Although the technical mechanisms differ, all onboarding solutions pursue the same objective: establishing a cryptographic root of trust that enables the device to authenticate itself and securely obtain operational credentials. The selected onboarding mechanism directly influences the achievable security level, deployment complexity, and scalability of the resulting IoT system.

Strategy	Initial Trust	Advantages	Limitations	Typical Deployment
Pre-shared Key (PSK)	Manufacturer-provisioned secret	Very lightweight and simple to deploy	Poor scalability; difficult key rotation	Small-scale IoT deployments
Certificate-based Enrollment	PKI / X.509 certificates	Strong identity assurance and scalability	Certificate management overhead	Industrial IoT infrastructures
Dynamic Provisioning	Bootstrap server issues credentials	Automated credential lifecycle and flexible deployment	Requires secure onboarding infrastructure	Large cloud-based IoT systems

Table 2: Comparison of IoT device onboarding strategies.

Authentication begins before the first operational message is exchanged. A device must first establish a secure communication channel during the onboarding phase and then be enrolled by registering its identity and credentials within the system. Although these steps are often performed together, the literature distinguishes secure channel establishment from identity registration, since a confidential communication channel alone does not guarantee that the communicating device is legitimate [1, 5].

3.2 Device Identity and Credential Management

Before a device can authenticate itself, it must possess an identity and one or more credentials that allow other entities to verify its legitimacy. Device identity constitutes the foundation of any authentication mechanism and enables the infrastructure to distinguish legitimate devices from unauthorized or counterfeit entities.

IoT systems employ various identity models depending on deployment requirements and resource constraints. Traditional approaches rely on static identifiers such as serial numbers, MAC addresses, or manufacturer-issued device identifiers. However, identifiers alone are insufficient because they can often be observed or spoofed. For this reason, authentication systems associate identities with cryptographic credentials.

The most common credential types employed in IoT systems are summarized in Table 3.

Credential	Cryptographic Basis	Advantages	Limitations	Typical Use
Pre-shared Key (PSK)	Symmetric key	Lightweight and efficient	Complex key distribution and rotation	Constrained IoT devices
X.509 Certificate	Public Key Infrastructure (PKI)	Strong authentication and interoperability	Certificate lifecycle management	Industrial IoT systems
ECC Key Pair	Public-key cryptography	Scalable and compact keys	Higher computational cost than symmetric methods	Modern IoT deployments
TPM / Secure Element	Hardware root of trust	Tamper-resistant credential storage	Additional hardware cost	Critical infrastructure devices
Physical Unclonable Function (PUF)	Hardware fingerprint	Clone-resistant device identity	Manufacturing dependency	Secure embedded systems
DID Credential	Decentralized public-key infrastructure	No centralized certification authority	Immature ecosystem and interoperability challenges	SSI-enabled IoT platforms

Table 3: Comparison of device identity and credential mechanisms.

In practice, the choice of identity and credential model strongly influences the design of the authentication architecture. Resource-constrained IoT deployments often favor lightweight symmetric credentials, whereas larger infrastructures increasingly adopt public-key mechanisms to improve scalability and facilitate credential lifecycle management [7, 2].

3.3 Authentication Mechanisms for Constrained Devices

Authentication mechanisms enable devices to prove possession of valid credentials and establish trust with other entities participating in the system. In IoT environments, authentication protocols must account for limited processing power, memory constraints, and energy consumption while maintaining adequate security guarantees.

The literature generally distinguishes between symmetric and asymmetric authentication approaches.

Symmetric Authentication

Symmetric authentication relies on a secret shared between communicating entities. Common implementations use challenge-response protocols combined with cryptographic hash func-

tions or message authentication codes (HMAC). These mechanisms typically require limited computational resources and are therefore attractive for highly constrained devices.

However, symmetric approaches present scalability challenges because secret keys must be securely distributed, stored, and renewed throughout the system lifecycle.

Asymmetric Authentication

Asymmetric authentication uses public-private key pairs to prove identity. Examples include certificate-based authentication and digital signature schemes based on elliptic-curve cryptography (ECC). These approaches simplify large-scale key management and eliminate the need for pairwise shared secrets.

Although asymmetric cryptography traditionally imposed higher computational costs, modern lightweight ECC implementations have significantly improved its applicability in constrained IoT devices [2].

Lightweight Authentication

Recent research has proposed lightweight authentication protocols specifically optimized for IoT environments. These protocols aim to reduce communication overhead, computational complexity, and energy consumption while preserving resistance against common attacks such as impersonation, replay, and credential theft.

Table 4 summarizes representative authentication mechanisms and their characteristics.

Mechanism	Authentication Factor	IoT Suitability	Scalability	Main Limitation
Password / PSK	Shared secret	High	Medium	Secret distribution and renewal
X.509 Certificate	Public-key cryptography	Medium	High	PKI management overhead
ECC Signatures	Public-key cryptography	High	High	Higher computational cost
Token-based Authentication	Cryptographic token	High	High	Requires token freshness and secure storage
PUF-based Authentication	Hardware fingerprint	High	Medium	Specialized hardware required
Multi-factor Authentication	Multiple authentication factors	Low	Low	Unsuitable for autonomous M2M communications

Table 4: Comparison of authentication mechanisms for IoT systems.

3.4 Authentication Architectures

Beyond the cryptographic mechanisms themselves, IoT deployments also differ in the way authentication services are organized. The literature generally distinguishes three architectural models: centralized, federated, and decentralized authentication. Each model distributes trust differently and therefore presents distinct trade-offs in terms of scalability, resilience, interoperability, and operational complexity.

Centralized Architectures

Centralized architectures rely on a dedicated authentication authority responsible for credential validation and trust management. This model simplifies administration and remains the most common approach in industrial and cloud-based IoT deployments.

Federated Architectures

Federated architectures distribute authentication responsibilities across multiple trusted domains. These approaches improve interoperability and scalability while allowing independent administrative entities to cooperate.

Decentralized Architectures

Decentralized architectures reduce reliance on centralized trust anchors by leveraging distributed identity mechanisms and cryptographic verification. Emerging approaches based on Self-Sovereign Identity (SSI) and Decentralized Identifiers (DIDs) illustrate this trend.

Table 5 compares the principal architectural models.

The architecture selected for an IoT deployment influences not only authentication procedures but also trust distribution, fault tolerance, operational complexity, and scalability.

Architecture	Trust Model	Advantages	Limitations
Centralized	Single authentication server	Simple administration and policy enforcement	Single point of failure and limited resilience
Federated	Multiple trusted domains	Improved interoperability and administrative flexibility	Requires trust coordination between domains
Decentralized	Distributed trust infrastructure	Reduced dependence on centralized authorities	Higher implementation and operational complexity

Table 5: Comparison of authentication architectures for IoT systems.

3.5 Authorization and Access Control

Authentication establishes the identity of a device, whereas authorization determines the actions that the device is permitted to perform after successful authentication. Both functions are complementary and constitute essential components of secure IoT infrastructures.

Traditional authorization models rely on Role-Based Access Control (RBAC), where permissions are assigned according to predefined roles. For example, a sensor may only publish measurements, while an administrator may modify system configurations.

More flexible approaches employ Attribute-Based Access Control (ABAC), where authorization decisions depend on contextual information such as device type, location, operational state, or time constraints. These models are particularly attractive in heterogeneous IoT environments because they enable fine-grained policy enforcement.

Table 6 summarizes representative access-control models for IoT systems.

Model	Principle	IoT Suitability	Typical Use
MAC	Access controlled by centrally enforced security policies	Low — Too rigid for dynamic IoT environments	Military and high-security systems
DAC	Resource owners determine access permissions	Low — Ownership model is difficult to apply to IoT	Traditional operating systems
RBAC	Permissions assigned according to predefined roles	Medium — Suitable for static deployments	Enterprise IoT platforms
ABAC	Policies based on subject, object, and contextual attributes	Very High — Supports dynamic and context-aware decisions	Large-scale heterogeneous IoT environments
Capability-Based Access Control (CapBAC)	Capability tokens grant specific permissions	High — Well suited for distributed M2M communications	Decentralized IoT systems

Table 6: Comparison of access control models for IoT systems.

In MQTT-based systems, authorization is commonly implemented through topic-level access control rules. Devices may be granted permission to publish or subscribe only to specific topics, thereby limiting the impact of compromised devices and reducing unauthorized data access [9, 10].

Recent Zero Trust architectures extend traditional authorization concepts by continuously reevaluating trust decisions throughout the communication lifecycle. Instead of granting permanent access after successful authentication, authorization decisions may be periodically reassessed using behavioral, contextual, or risk-based indicators [18, 16].

Overall, the literature shows that secure IoT authentication cannot rely on a single mechanism. Effective solutions combine secure onboarding, robust device identities, lightweight authentication protocols, scalable authentication architectures, and appropriate access control policies. These

building blocks provide the foundation for the MQTT-based authentication architecture and anomaly detection framework discussed in the following sections.

4 Messaging, Edge, and Continuous Verification

4.1 MQTT Security

MQTT is widely used in IoT systems because of its lightweight publish/subscribe model, in which publishers and subscribers communicate indirectly through a broker. However, MQTT does not provide complete security by default. Depending on the deployment configuration, it may be exposed to weak authentication, unauthorized topic access, replay, broker abuse, and denial-of-service attacks unless additional protection mechanisms are introduced [10, 11, 13].

Transport protection, token-based authorization, broker-side access control, and message-integrity mechanisms can be combined to strengthen MQTT deployments. The experimental evaluation of ACE-MQTT on a Raspberry Pi 3B+ provides a useful illustration of the cost introduced by authentication and authorization mechanisms. Table 7 summarizes the reported overhead.

Metric	Plain MQTT	ACE-MQTT	Overhead factor
Network resources (auth)	Baseline	$\times 10$	$10\times$
CPU usage (auth)	Baseline	$\times 3$	$3\times$
Memory (auth)	Baseline	$\times 1.2$	$1.2\times$
Energy (auth)	Baseline	$+10\%$	$1.1\times$
Network (normal session)	Baseline	$+15\%$	$1.15\times$
CPU (normal session)	Baseline	$\approx 0\%$	$\approx 1\times$

Auth time split: TLS handshake $\approx 90\%$ | token request $\approx 8\%$ | broker auth $\approx 2\%$. Source: [9].

Table 7: Authentication cost decomposition: ACE-MQTT vs. plain MQTT.

The results indicate that the largest security cost occurs during session establishment, particularly during the TLS handshake, whereas the additional cost during normal message exchange is considerably lower. This distinction is relevant for constrained devices because frequent reconnections or re-authentication operations may have a greater impact than steady-state communication.

Table 8 compares representative communication and security approaches considered for constrained IoT environments [8, 2, 12].

Approach	Primary Use	Security Support	Overhead	Suitability for Constrained IoT
MQTT + TLS	Protected publish/subscribe messaging	pub- Transport confidentiality and server/device authentication	Medium	Moderate
MQTT + ACE/OAuth2	Token-based MQTT authorization	Scoped tokens and proof of possession	Medium	Moderate
CoAP + DTLS	Constrained request/response communication	re- PSK- or certificate-based channel protection	Low	High
SEC-RMC	Lightweight secure messaging	Symmetric encryption and key-based authentication	Very low	High
TLS	General transport security	Certificate- or PSK-based authentication	High	Low to moderate
HMAC / BLAKE2s	Message integrity and authenticity	Shared-secret integrity protection	Very low	Very high
OAuth2 / ACE	Authorization framework	Token-based delegated authorization	Medium	Moderate

Table 8: Comparison of communication and security approaches for constrained IoT systems.

These approaches are complementary rather than mutually exclusive. In practice, an IoT deployment may combine MQTT for messaging, TLS for channel protection, token-based authorization for resource access, and lightweight integrity mechanisms for selected constrained interactions.

4.2 Zero Trust Architecture

Zero Trust replaces implicit perimeter-based trust with explicit, continuous, and context-aware verification. Its central principle is commonly summarized as *never trust, always verify* [18, 16]. This approach is particularly relevant to IoT systems because a device that was legitimately enrolled and authenticated may later be compromised, misconfigured, or used outside its expected

context.

Table 9 summarizes the main Zero Trust principles and their application in IoT environments.

Principle	Definition	IoT Application
No implicit trust based on location	Entities must be verified regardless of network position	Enrolled devices are not automatically trusted after joining the network
Least privilege	Only the minimum permissions required for the current task are granted	Topic-specific token scopes and fine-grained access-control policies
Explicit resource protection	Devices, services, flows, and data are treated as protected resources	Broker-side ACL enforcement and authorization checks
Continuous monitoring	Trust is periodically reassessed using observed behavior and context	Event logging, trust-score updates, and re-authentication when required
Segmentation	Network and service domains are isolated to limit compromise propagation	Separated IoT domains and restricted communication paths

Table 9: Zero Trust principles and their application in IoT systems.

A central concept in Zero Trust Architecture is the separation between the Policy Decision Point (PDP), which evaluates access requests, and the Policy Enforcement Point (PEP), which applies the resulting decisions [18, 15, 17]. This separation supports distributed enforcement close to protected resources while maintaining coherent policy management.

However, distributed enforcement does not automatically eliminate all central points of failure. The resilience of the architecture still depends on the availability, replication, and protection of policy-decision and identity-management services. For IoT systems, this makes the placement and protection of enforcement components an important architectural decision.

4.3 Edge-Based Security Enforcement

The edge layer provides a practical location for enforcing security decisions in IoT systems. Compared with constrained end devices, gateways and edge nodes generally offer greater processing, storage, and monitoring capabilities. At the same time, their proximity to devices allows them to react more rapidly than remote cloud services [3, 14, 21].

In the considered architecture, the gateway can act as an intermediary between devices, authentication services, and MQTT resources. Its role may include forwarding authentication requests, validating access conditions, monitoring authentication behavior, and applying local

enforcement decisions. This positioning also allows the gateway to correlate events from multiple devices and identify anomalies that may not be visible from a single endpoint.

Table 10 summarizes representative security functions that can be deployed at the edge.

Function	Description	Project Relevance
Authentication proxy	Relays or mediates authentication between devices and remote services	Supports device–gateway–server authentication flows
Cryptographic offloading	Executes resource-intensive cryptographic operations on behalf of constrained devices	Reduces processing requirements on end devices
Access-control enforcement	Validates token scope, topic permissions, or contextual policies	Prevents unauthorized MQTT publish/subscribe operations
Event monitoring	Collects authentication, session, and communication events	Provides input for behavioral anomaly detection
Local anomaly response	Applies actions such as throttling, blocking, or re-authentication	Enables rapid reaction to suspicious behavior
Firmware validation	Verifies firmware signatures or hashes before distribution	Reduces unauthorized or tampered updates
Privacy-preserving processing	Filters, aggregates, or transforms data before cloud transmission	Limits unnecessary exposure of device and behavioral data

Table 10: Security functions that can be deployed at the IoT edge.

The gateway is nevertheless a high-value target because it concentrates authentication, monitoring, and enforcement responsibilities. Its trustworthiness should therefore not be assumed

unconditionally. Compromise of the gateway could allow an attacker to manipulate authentication events, suppress alerts, or alter access-control decisions. The literature proposes mechanisms such as secure boot, hardware-backed key storage, remote attestation, process isolation, and hardened execution environments to reduce this risk [14, 19, 20].

For the initial scope of this project, the gateway is treated as a trusted enforcement and observation component. This assumption simplifies the first implementation of the simulator, but gateway compromise remains an important scenario for future extensions.

Overall, MQTT provides the messaging context in which authentication and authorization events occur, while Zero Trust introduces the need for continuous verification beyond the initial login phase. The edge gateway connects these two perspectives by acting as a local observation and enforcement point. Together, these elements define the architectural context in which authentication anomalies will be represented and analyzed in the simulator.

5 Authentication Attacks and Behavioral Anomalies

5.1 Authentication-Specific Attacks

Authentication anomalies may occur at any phase of the device lifecycle, including onboarding, credential verification, session establishment, authorization, and credential renewal. Unlike general network attacks, authentication-specific attacks directly manipulate identities, credentials, freshness mechanisms, or the expected order of security operations [11, 22, 23].

For the purposes of this project, the most relevant attacks are those that produce observable inconsistencies between a device identity, its credentials, the current session, and the sequence of authentication events. Table 11 summarizes the main authentication-specific attacks identified in the literature and the signals that may be represented in the generated traces.

Attack	Mechanism	Observable Indicators
Token replay	A previously valid token is reused outside its intended session or validity context	Repeated token identifier, expired token, token reused across sessions
Nonce reuse	A previously issued challenge value is submitted again	Duplicate nonce, nonce age above validity window, repeated challenge-response pair
Timestamp manipulation	Authentication messages contain inconsistent or deliberately modified timestamps	Negative time difference, excessive clock deviation, event ordering inconsistency
Impersonation	An attacker attempts to authenticate using a forged, cloned, or stolen device identity	Unknown device identifier, proof-of-possession failure, unusual source address
Identity-token mismatch	A valid token is presented by a device or session for which it was not issued	Device identifier differs from token subject, session-token inconsistency
Unauthorized access before authentication	A device requests a protected resource without completing the expected authentication flow	Access event without preceding authentication success or active session
Abnormal credential renewal	A device requests token or credential renewal at an unexpected frequency or state	Repeated early renewal, excessive refresh rate, renewal after revocation
Authentication flooding	A device repeatedly initiates authentication requests to exhaust gateway, broker, or server resources	Burst of requests, high failure rate, abnormal connection frequency
Protocol downgrade	An attacker forces the use of a weaker authentication or transport configuration	Unexpected protocol version, missing security option, weaker cipher or authentication mode

Table 11: Authentication-specific attacks and their observable indicators.

Replay attacks are particularly relevant because they abuse valid authentication material rather than breaking the underlying cryptographic primitive. Their detection therefore depends on contextual information such as timestamps, nonces, token identifiers, session state, and event ordering. These attributes can be represented explicitly in authentication traces and used by rule-based or machine-learning detection mechanisms [24].

5.2 Behavioral and Post-Authentication Anomalies

A successful authentication does not guarantee that a device will remain trustworthy throughout the session. A legitimate device may later be compromised, misconfigured, cloned, or used in a

manner that deviates from its expected operational profile. These cases are difficult to identify using cryptographic verification alone because the attacker may possess valid credentials.

Behavioral anomaly detection therefore focuses on deviations from historical or expected patterns. Relevant observations include authentication frequency, failure rate, token-renewal behavior, requested resources, message rate, session duration, and consistency between device identity and communication context.

Table 12 summarizes representative post-authentication anomalies relevant to the project.

Anomaly	Behavioral Description	Observable Indicators
Abnormal failure rate	A device repeatedly fails authentication beyond its normal behavior	High failure ratio, repeated retries, short intervals between attempts
On–off behavior	A device alternates between normal and malicious behavior to avoid detection	Periodic bursts of anomalies separated by normal activity
Session behavior deviation	An authenticated device changes its usual communication or access pattern	Unexpected session duration, unusual topics, abnormal request sequence
Compromised-device behavior	A legitimate device with valid credentials begins performing unauthorized or atypical actions	Valid authentication followed by policy violations or abnormal resource access
Device identity cloning	The same device identity appears simultaneously in incompatible contexts	Concurrent sessions, different source addresses, inconsistent gateway association
Abnormal message frequency	A device communicates at a rate significantly different from its established baseline	Message-rate spike, unusually long inactivity, irregular periodicity
Unexpected authorization behavior	A device requests resources or permissions outside its normal operational profile	New topic access, unusual token scope, repeated denied requests

Table 12: Representative behavioral and post-authentication anomalies.

These anomalies require combining authentication-state information with temporal, session, identity, and communication features. This motivates the generation of event traces that preserve both the order of authentication operations and the broader behavioral context in which they occur.

5.3 Trust Management Systems

Trust Management Systems (TMS) complement cryptographic authentication by evaluating whether an authenticated entity continues to behave as expected. Cryptography can verify

possession of valid credentials and protect message integrity, but it cannot by itself determine whether a legitimate device has been compromised or is behaving abnormally [22].

A TMS generally derives a dynamic trust value from direct observations, historical behavior, contextual information, or recommendations from other entities. Trust values are therefore updated over time rather than treated as a permanent binary property. Table 13 summarizes representative approaches used to compute or update trust in IoT systems.

Approach	Representative Methods	Strengths and Limitations
Rule- and threshold-based	Failure counters, rate limits, fixed trust thresholds	Simple and interpretable, but may not adapt well to changing device behavior
Statistical and probabilistic	Bayesian models, entropy, hidden Markov models	Supports uncertainty and temporal evolution, but requires suitable parameterization
Machine-learning-based	Classification, clustering, anomaly detection, deep learning	Can detect complex behavioral patterns, but depends on representative training data
Reputation-based	Direct observations, recommendations, reputation aggregation	Useful in distributed environments, but vulnerable to false or manipulated reports
Hybrid approaches	Combination of rules, statistical models, and machine learning	Offers broader detection coverage, but increases design and computational complexity

Table 13: Representative trust-management approaches for IoT systems. Adapted from [22].

Within the scope of this project, trust management is not treated as a replacement for cryptographic authentication. Instead, behavioral indicators may be used to complement binary authentication results with a dynamic assessment of device activity. The initial simulator will primarily generate the observations required for such an assessment, including failure frequency, token reuse, state inconsistencies, renewal patterns, and deviations from expected session behavior.

Overall, the reviewed attacks show that authentication security must be evaluated at two complementary levels. The first concerns explicit violations of authentication rules, such as token replay, nonce reuse, identity mismatch, or access without prior authentication. The second concerns behavioral deviations occurring after technically valid authentication. This distinction provides the basis for defining both deterministic anomaly-injection rules and behavioral features in the simulator.

6 Datasets and Synthetic Data Generation

Datasets are required to develop, train, and evaluate anomaly-detection mechanisms. In IoT security research, however, collecting representative data is difficult because real attacks are uncommon, operational traces may contain sensitive information, and authentication events are not always logged with sufficient contextual detail. Existing MQTT datasets provide useful network- and protocol-level observations, but they do not fully represent the sequence of states and decisions involved in an authentication lifecycle.

6.1 Existing IoT and MQTT Security Datasets

Several public datasets have been proposed for evaluating intrusion-detection mechanisms in MQTT-based environments. They commonly include benign traffic and selected attacks, such as flooding, malformed messages, unauthorized connections, or abnormal publish/subscribe activity. These datasets are useful for studying network-level detection, protocol behavior, and feature extraction.

Table 14 summarizes the datasets and related experimental works considered in this review.

Dataset / Work	Main Characteristics	Limitation for This Project
MQTTset [27]	Smart-home MQTT traffic containing benign activity and five attack categories; distributed as PCAP files and extracted features	Does not explicitly represent onboarding, credential validation, token state, or re-authentication
DoS/DDoS-MQTT-IoT [25]	Large MQTT testbed dataset focused on denial-of-service and distributed denial-of-service activity, including attacks against connection establishment	Primarily represents flooding behavior and provides limited authentication-state context
MQTT threat characterization [26]	Analysis and feature selection over MQTT-oriented attack data for machine-learning detection	Focuses on protocol and traffic features rather than authentication lifecycle transitions
MQTT-IoT-IDS2020	Simulated MQTT traffic represented through packet-, unidirectional-flow-, and bidirectional-flow-level features	Useful for intrusion detection, but does not model credential renewal or authentication-state consistency

Table 14: Comparison of representative IoT and MQTT security datasets.

These works confirm the value of MQTT traffic datasets for evaluating intrusion-detection methods. Nevertheless, their records are generally organized around packets, flows, connections, or attack labels rather than the internal state of the authentication process. For the present project, additional information is required to determine whether an event is consistent with the device identity, credential status, session state, and expected authentication sequence.

6.2 Synthetic Data Generation

Synthetic data generation provides an alternative when representative operational traces are unavailable, sensitive, difficult to label, or insufficiently detailed. Instead of passively collecting traffic, a controlled environment can reproduce legitimate behavior and inject predefined anomalies while preserving the parameters and ground-truth label associated with each event.

The literature identifies several complementary approaches to synthetic cybersecurity data generation. Table 15 summarizes the approaches most relevant to this project.

Approach	Main Principle	Relevance and Limitation
Rule-based simulation	Generates events from explicit entities, states, transitions, and probability distributions	Provides full control and interpretability, but realism depends on the quality of the modeled assumptions
Attack injection	Introduces labeled attacks into legitimate or background traffic [29]	Supports reproducible comparisons and known ground truth, but injected behavior must remain contextually realistic
Scenario-based simulation	Executes predefined legitimate and malicious scenarios under controlled configurations [30]	Useful for studying system dynamics and temporal dependencies, but requires careful scenario design
Generative machine learning	Learns the statistical distribution of existing traffic and generates new samples, for example using GAN-based approaches [28, 31]	Can increase diversity, but may reproduce dataset bias and does not automatically preserve authentication semantics
Hybrid generation	Combines explicit state-machine rules with statistical or learned variation	Can preserve domain constraints while increasing behavioral diversity, but introduces additional implementation complexity

Table 15: Synthetic data-generation approaches relevant to IoT security experiments.

For this project, rule- and scenario-based simulation provides the most appropriate starting point because authentication behavior depends on explicit temporal and logical relationships. Examples include the requirement that onboarding precedes authentication, that a token must belong to the current device and session, and that renewal should occur only under valid credential conditions. These constraints are difficult to preserve using purely statistical generation.

The simulator can nevertheless introduce controlled variability through device profiles, timing distributions, failure probabilities, communication rates, and attack parameters. This combination enables repeated experiments while retaining a known relationship between the generated event, the system state, and the associated anomaly label.

6.3 Limitations of Existing Datasets

Among the datasets examined in this review, none explicitly represents the complete IoT authentication lifecycle required by the project. Existing datasets mainly describe traffic behavior and protocol-level attacks, while providing limited information about the state and dependencies of authentication operations.

The principal limitations identified are the following:

- **Limited lifecycle representation:** onboarding, enrollment, authentication, authorization, session establishment, and renewal are rarely represented as distinct phases.
- **Insufficient identity context:** device identifiers, credential ownership, token subject, session association, and gateway context are not always recorded together.
- **Weak temporal semantics:** event order, nonce lifetime, token age, renewal frequency, and delay between authentication steps are often absent.
- **Restricted attack coverage:** many datasets emphasize flooding or network-level attacks rather than token replay, identity–token mismatch, nonce reuse, or access without prior authentication.
- **Limited behavioral history:** individual records may not preserve enough session or device history to identify post-authentication deviations.
- **Reproducibility constraints:** some datasets do not provide the complete configuration, generation parameters, or scenario logic required to reproduce their traces.

These limitations justify the development of a domain-specific simulator that produces labeled authentication events rather than only network packets or aggregated flows. The generated data should preserve entity relationships, state transitions, temporal dependencies, credential status, session context, and attack parameters.

The simulator is not intended to replace real testbeds or public traffic datasets. Instead, it complements them by providing authentication-specific traces that can later be combined with network measurements or validated against practical deployments.

Overall, existing MQTT datasets provide useful references for traffic volume, protocol behavior, attack representation, and feature organization. Synthetic generation extends these resources by enabling controlled and reproducible authentication scenarios. The main requirement for this project is therefore not simply to generate more traffic, but to produce traces in which authentication state, temporal order, identity consistency, and anomaly labels are explicitly preserved.

7 Research Gap and Project Positioning

7.1 Research Gap

The literature reviewed throughout this document highlights a consistent limitation: existing IoT security datasets primarily focus on network traffic, protocol behavior, or generic intrusion-detection scenarios. While these datasets are valuable for evaluating communication-level attacks, they rarely capture the complete authentication lifecycle of IoT devices.

In particular, the surveyed datasets do not explicitly model the succession of onboarding, credential provisioning, authentication, authorization, session establishment, credential renewal, and trust re-evaluation events. Likewise, authentication-specific anomalies such as token replay, nonce reuse, identity–token inconsistencies, abnormal credential renewal, or access attempts without prior authentication are generally absent or only indirectly observable [27, 25, 26].

As a consequence, current datasets provide limited support for studying authentication-aware anomaly detection mechanisms. Detecting such anomalies requires not only communication features but also explicit information about device identities, credentials, session state, temporal dependencies, and authentication context.

7.2 Project Positioning

To address this limitation, the project proposes the development of a synthetic data generator dedicated to IoT authentication scenarios. Rather than focusing exclusively on network traffic, the objective is to model the authentication lifecycle itself and produce labeled event traces that preserve entity relationships, state transitions, temporal consistency, and attack context.

The proposed approach adopts a device–gateway–cloud architecture representative of many contemporary IoT deployments. Devices interact with services through a gateway that mediates authentication exchanges, enforces authorization and policy decisions, and monitors device behavior before access to MQTT resources is granted. Authentication events generated within this architecture can then be enriched with contextual information such as device identity, credential status, session state, trust indicators, and authorization decisions.

The simulator is intended as a research tool rather than a replacement for operational testbeds. Its primary purpose is to generate reproducible and controllable authentication traces that can be used to evaluate anomaly-detection techniques, compare detection strategies, and support future machine-learning experiments. By explicitly modeling authentication behavior and its associated anomalies, the simulator aims to bridge the gap identified between existing IoT datasets and the requirements of authentication-centric security research.

8 Design Choices Derived from the Literature Review

This section gathers every design choice the review supports. Each decision is a selection from the comparative tables of Section 3.

8.1 Reference Authentication Model

The literature review identified authentication as a multi-stage process rather than a single event. Consequently, the simulator will model authentication as a sequence of dependent phases whose order and consistency can be verified throughout the lifecycle.

The retained reference model consists of seven phases:

1. Device discovery;

2. Secure pairing;
3. Device enrollment;
4. Device authentication;
5. Authorization;
6. MQTT session establishment;
7. Credential renewal or re-authentication.

Representing these phases explicitly allows the simulator to generate both legitimate and anomalous behaviors while preserving the temporal dependencies observed in real deployments. It also provides a natural framework for injecting authentication-specific anomalies such as replay attacks, identity inconsistencies, abnormal credential renewal, or access attempts performed without completing the required preceding phases.

The authentication model therefore serves as the state machine underlying the generation of synthetic authentication traces.

8.2 Retained Architectural and Protocol Choices

Table 16 records the stack selected from the comparisons above, each with the table that justifies it.

Dimension	Decision	Justification
Detection location	Edge / gateway	Resources + proximity + multi-device visibility (Tab. 10) [3]
Messaging protocol	MQTT v5	Native re-auth and challenge-based auth; low steady-state overhead (Tab. 7) [9]
Credential and authorization model	Initial device credential with short-lived authorization tokens	Separates device authentication from resource authorization and supports controlled credential renewal [9]
Access control	ABAC	Context-aware; fits mobile IoT (Tab. 6) [6, 2]
Security paradigm	Zero Trust (NIST ZTA)	PDP/PEP; continuous verification (Tab. 9) [16, 18]
Cryptographic approach	Lightweight modern cryptography	Suitable for constrained devices while preserving strong security guarantees
Trust evaluation	Behavioral monitoring and continuous verification	Authentication alone is insufficient after device compromise
Data generation and detection	Rule- and scenario-based synthetic generation; ML-based evaluation in later stages	Authentication-aware labeled data are not available in the reviewed datasets (Tabs. 14 and 15) [29, 30, 22]

Table 16: Retained simulator design decisions with literature justification.

The selected technologies should not be interpreted as fixed implementation constraints. Rather, they define the reference environment used to generate authentication traces and evaluate anomaly-detection mechanisms. Alternative protocols or cryptographic primitives may be substituted in future iterations provided that the same authentication semantics and state transitions are preserved.

8.3 Implications for Simulator Design

The literature review highlights several requirements that directly influence the simulator architecture.

First, authentication events must be generated together with their operational context. Device identities, credentials, sessions, authorization decisions, and communication events cannot be represented independently because many anomalies emerge precisely from inconsistencies between these elements.

Second, temporal dependencies must be preserved. Authentication traces should maintain the

ordering constraints that exist in operational systems, such as enrollment preceding authentication, authentication preceding authorization, and authorization preceding resource access.

Third, the simulator must explicitly represent state transitions. Devices should evolve through identifiable states, allowing attacks and anomalies to be injected at specific phases of the authentication lifecycle rather than appearing as isolated events.

Fourth, anomaly generation should remain controllable and reproducible. Each injected anomaly must be associated with known parameters and ground-truth labels in order to support future evaluation of detection mechanisms.

Finally, authentication should not be considered a permanent trust decision. The simulator should therefore support the generation of post-authentication behavioral anomalies and contextual inconsistencies that reflect the principles of continuous verification and Zero Trust architectures.

These observations define the main requirements that will guide the design and implementation of the authentication-event simulator developed in the next stages of the project.

9 Conclusion

This deliverable reviewed the main concepts, technologies, and architectural approaches relevant to authentication-centric security in IoT systems. The analysis covered device onboarding, identity and credential management, authentication mechanisms, authorization models, MQTT security, Zero Trust architectures, edge-based enforcement, authentication attacks, trust management, and existing IoT security datasets.

The review highlighted several recurring observations. First, authentication in IoT is not a single operation but a lifecycle involving onboarding, credential provisioning, authentication, authorization, session establishment, and credential renewal. Second, MQTT remains one of the most widely adopted communication protocols for IoT deployments, but secure operation requires complementary mechanisms such as TLS, token-based authorization, and access-control policies. Third, modern security architectures increasingly rely on Zero Trust principles and edge-based enforcement to continuously evaluate device behavior rather than assuming trust after a successful authentication.

The survey also identified a significant limitation in the current state of the art. Existing IoT security datasets primarily focus on network traffic and protocol-level attacks, while providing limited visibility into authentication state, credential lifecycle, temporal dependencies, and authentication-specific anomalies. As a result, they offer limited support for evaluating authentication-aware anomaly detection approaches.

To address this gap, the project adopts a synthetic data generation approach centered on the authentication lifecycle. The simulator will model the interactions between devices, gateways, authentication services, and MQTT infrastructure while preserving state transitions, entity relationships, temporal consistency, and attack context. This approach aims to produce reproducible and labeled authentication traces that can support future research on anomaly

detection, trust evaluation, and intelligent security mechanisms for IoT environments.

References

- [1] S. Khalfaoui. “Security Bootstrapping for Internet of Things”. PhD thesis. Institut Polytechnique de Paris, 2022.
- [2] E. Lara, L. Aguilar, M. A. Sanchez, and J. A. García. “Lightweight Authentication Protocol for M2M Communications of Resource-Constrained Devices in Industrial Internet of Things”. In: *Sensors* 20.2 (2020), p. 501.
- [3] K. Sha, T. A. Yang, W. Wei, and S. Davari. “A Survey of Edge Computing-Based Designs for IoT Security”. In: *Digital Communications and Networks* 6.2 (2020), pp. 195–202.
- [4] A. N. Alsheavi, A. Hawbani, W. Othman, X. Wang, G. Qaid, L. Zhao, A. Al-Dubai, L. Zhi, A. S. Ismail, R. Jhaveri, S. Alsamhi, and M. A. A. Al-Qaness. “IoT Authentication Protocols: Challenges and Comparative Analysis”. In: *ACM Computing Surveys* 57.5 (2025), p. 116.
- [5] H. Gupta and P. C. van Oorschot. “Onboarding and Software Update Architecture for IoT Devices”. In: *Proceedings of the IEEE International Conference on Communications Workshops*. IEEE, 2019.
- [6] M. Trnka, T. Cerny, and N. Stickney. “Survey of Authentication and Authorization for the Internet of Things”. In: *Security and Communication Networks* 2018 (2018), p. 4351603.
- [7] X. Zhu and Y. Badr. “Identity Management Systems for the Internet of Things: A Survey Towards Blockchain Solutions”. In: *Sensors* 18.12 (2018), p. 4215.
- [8] S. Va, V. A, and S. Pattar. “MQTT-Based Secure Transport Layer Communication for Mutual Authentication in IoT Networks”. In: *Global Transitions Proceedings* 3 (2022), pp. 60–66.
- [9] M. Michaelides, C. Sengul, and P. Patras. “An Experimental Evaluation of MQTT Authentication and Authorization in IoT”. In: *Proceedings of the ACM Workshop on Wireless Network Testbeds, Experimental Evaluation and Characterization*. WiNTECH. New Orleans, USA: ACM, 2022.
- [10] D. Dinculeană and X. Cheng. “Vulnerabilities and Limitations of MQTT Protocol Used between IoT Devices”. In: *Applied Sciences* 9.5 (2019), p. 848.
- [11] S. Andy, B. Rahardjo, and B. Hanindhito. “Attack Scenarios and Security Analysis of MQTT Communication Protocol in IoT Systems”. In: *Proceedings of the International Conference on Electrical Engineering, Computer Science and Informatics*. Indonesia, 2017.
- [12] H.-Y. Chien, A.-T. Shih, and Y.-M. Huang. “Exploring MQTT Broker-Based, End-to-End Models for Security and Efficiency”. In: *Sensors* 25 (2025), p. 5308.

- [13] P. Verma. “MQTT Security Challenges and Solutions”. In: *International Journal of Enhanced Research in Science, Technology and Engineering* 11.4 (Apr. 2022).
- [14] M. McCormack et al. *Towards an Architecture for Trusted Edge IoT Security Gateways*. Tech. rep. Carnegie Mellon University, n.d.
- [15] C. Zanasi, S. Russo, and M. Colajanni. “Flexible Zero Trust Architecture for the Cybersecurity of Industrial IoT Infrastructures”. In: *Ad Hoc Networks* 156 (2024).
- [16] H. Kang et al. “Theory and Application of Zero Trust Security: A Brief Survey”. In: *Entropy* 25 (2023).
- [17] S. Li, M. Iqbal, and N. Saxena. “Future Industry Internet of Things with Zero-Trust Security”. In: *Information Systems Frontiers* 26 (2024), pp. 1653–1666.
- [18] S. Rose, O. Borchert, S. Mitchell, and S. Connelly. *Zero Trust Architecture*. Tech. rep. NIST Special Publication 800-207. National Institute of Standards and Technology, 2020.
- [19] Q. Zhu, R. Wang, Q. Chen, Y. Liu, and W. Qin. “IoT Gateway: Bridging Wireless Sensor Networks into Internet of Things”. In: *Proceedings of the IEEE/IFIP International Conference on Embedded and Ubiquitous Computing*. IEEE, 2010, pp. 347–352.
- [20] J. Fan, Z. Wang, and C. Li. “Design and Implementation of IoT Gateway Security System”. In: *Proceedings of the International Conference on Artificial Intelligence and Advanced Manufacturing*. IEEE, 2019, pp. 156–162.
- [21] D. Canavese, L. Mannella, L. Regano, and C. Basile. “Security at the Edge for Resource-Limited IoT Devices”. In: *Sensors* 24.2 (2024), p. 590.
- [22] T. Sasi, A. H. Lashkari, R. Lu, P. Xiong, and S. Iqbal. “A Comprehensive Survey on IoT Attacks: Taxonomy, Detection Mechanisms and Challenges”. In: *Journal of Information and Intelligence* 2 (2024), pp. 455–513.
- [23] A. Khraisat and A. Alazab. “A Critical Review of Intrusion Detection Systems in the Internet of Things: Techniques, Deployment Strategy, Validation Strategy, Attacks, Public Datasets and Challenges”. In: *Cybersecurity* 4 (2021), p. 18.
- [24] S. Miri Kelaniki and N. Komninos. “A Study on IoT Device Authentication Using Artificial Intelligence”. In: *Sensors* 25.18 (2025), p. 5809.
- [25] A. Alatrani, L. F. Sikos, M. Johnstone, P. Szewczyk, and J. J. Kang. “DoS/DDoS-MQTT-IoT: A Dataset for Evaluating Intrusions in IoT Networks Using the MQTT Protocol”. In: *Computer Networks* 231 (2023), p. 109809.
- [26] Á. L. Muñoz Castañeda, J. A. Aveleira Mata, and H. Aláiz-Moretón. “Characterization of Threats in IoT from an MQTT Protocol-Oriented Dataset”. In: *Complex & Intelligent Systems* 9 (2023), pp. 5281–5296.
- [27] I. Vaccari, G. Chiola, M. Aiello, M. Mongelli, and E. Cambiaso. “MQTTset: A New Dataset for Machine Learning Techniques on MQTT”. In: *Sensors* 20.22 (2020), p. 6578.

- [28] S. Rahman, S. Pal, S. Mittal, T. Chawla, and C. Karmakar. “SYN-GAN: A Robust Intrusion Detection System Using GAN-Based Synthetic Data for IoT Security”. In: *Internet of Things* 26 (2024), p. 101212.
- [29] C. G. Cordero, E. Vasilomanolakis, A. Wainakh, M. Mühlhäuser, and S. Nadjm-Tehrani. “On Generating Network Traffic Datasets with Synthetic Attacks for Intrusion Detection”. In: *ACM Transactions on Privacy and Security* 24.2 (2021), p. 8.
- [30] H. Kavak, J. J. Padilla, D. Vernon-Bido, S. Y. Diallo, R. Gore, and S. Shetty. “Simulation for Cybersecurity: State of the Art and Future Directions”. In: *Journal of Cybersecurity* 7.1 (2021), tyab005.
- [31] S. Hui, H. Wang, Z. Wang, X. Yang, Z. Liu, D. Jin, and Y. Li. “Knowledge-Enhanced GAN for IoT Traffic Generation”. In: *Proceedings of the ACM Web Conference 2022*. ACM, 2022, pp. 3336–3346.